

Dependency & Supply-Chain Audit Trail

Project: **vulnerable-invoice-service** (com.demo.supplychain) · Run 2026-06-25 · SHA `61ed8c3` · Branch `fix/depSCAN-20260625-063826` **Health Score: 0 / 100 — Grade D**

Executive Summary

- 22 dependencies resolved (8 direct, 14 transitive) · 15 unique CVEs across 12 scored dependencies.
- Severity breakdown: **6 CRITICAL** **4 HIGH** **4 MEDIUM** **1 LOW**
- Supply-chain: **BLOCK** — 1 typosquatted coordinate (`com.fastxml...`) + 1 plaintext HTTP mirror removed in fix PR.
- Licenses: 1 violation — GPL-2.0 on `mysql:mysql-connector-java` (requires policy review — `MAJOR_REVIEW`).
- Stage 3 Remediation: 8 safe fixes batched onto `fix/depSCAN-20260625-063826` ; `mvn clean test` → **BUILD SUCCESS** (2/2 tests). Fix PR opened for human review.
- Gate verdict (pre-merge): **BLOCK** — unresolved CRITICAL CVEs on `main` ; fix PR clears all CRITICAL/HIGH/MEDIUM CVEs.

Health Score Breakdown

Factor	Weight	Deduction
Unresolved CRITICAL CVEs (6 × -10)	-60	from log4j, jackson-databind, typosquat
Unresolved HIGH CVEs (4 × -5)	-20	jackson-databind, guava
Supply-chain BLOCK findings (2 × -5)	-10	typosquat + HTTP mirror
Outdated dependencies (7 without CVE)	-5	commons-lang3, junit, jackson-core, etc.
License violation (1 × -5)	-5	GPL-2.0 on mysql-connector-java
Score (floored at 0)		0 / 100

Projected after fix PR merges: ~82 / 100 (Grade B). Remaining deductions: GPL-2.0 license violation (`MAJOR_REVIEW`, -10) and pre-existing JaCoCo 80% coverage gate (`BUILD_BROKEN`, -8).

Top Risks (Ranked by Risk Score)

Rank	Coordinate	Risk Score	Band	Top CVE	CVSS	Fix Applied
1	<code>com.fasterxml.jackson.core:jackson-databind:2.9.8</code>	9.3	CRITICAL	CVE-2019-16943	9.8	→ 2.13.4.2 ✓
2	<code>org.apache.logging.log4j:log4j-core:2.14.1</code>	8.5	CRITICAL	CVE-2021-44228	10.0	→ 2.17.2 ✓
3	<code>org.apache.logging.log4j:log4j-api:2.14.1</code>	8.5	CRITICAL	CVE-2021-44228	10.0	→ 2.17.2 ✓
4	<code>com.fastxml.jackson.core:jackson-databind:2.9.8</code>	8.5	CRITICAL	TYPOSQUAT	—	REMOVED ✓

5	<code>com.google.guava:guava:24.1.1-jre</code>	6.9	HIGH	CVE-2022-25647	7.7	→ 30.0-jre ✓
6	<code>mysql:mysql-connector-java:8.0.30</code>	5.4	MEDIUM	CVE-2023-21971	5.3	→ 8.0.33 ✓
7	<code>commons-io:commons-io:2.4</code>	4.9	MEDIUM	CVE-2021-29425	4.8	→ 2.7 ✓

Stage 3 Remediation — Consolidated Fix PR

Branch: `fix/depscan-20260625-063826`
Verification: `mvn clean test` → BUILD SUCCESS, 2/2 tests PASS

Coordinate	Old Version	New / Action	Type	Risk Band	CVEs Cleared
<code>com.fastxml.jackson.core:jackson-databind</code>	2.9.8	REMOVED	supply-chain removal	CRITICAL	n/a (typosquat)
HTTP mirror <code>internal-untrusted-mirror</code>	present	REMOVED	supply-chain removal	CRITICAL	n/a (plaintext HTTP)
<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	2.17.2	version bump	CRITICAL	CVE-2021-44228, CVE-2021-45046, CVE-2021-44832
<code>org.apache.logging.log4j:log4j-api</code>	2.14.1	2.17.2	version bump	CRITICAL	CVE-2021-44228, CVE-2021-45046
<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	2.13.4.2	version bump	CRITICAL	CVE-2019-16943, CVE-2019-14892, CVE-2019-14893, CVE-2019-14379, CVE-2021-20190, CVE-2020-36518, CVE-2022-42003, CVE-2022-42004
<code>com.google.guava:guava</code>	24.1.1-jre	30.0-jre	version bump	HIGH	CVE-2022-25647
<code>mysql:mysql-connector-java</code>	8.0.30	8.0.33	version bump	MEDIUM	CVE-2023-21971
<code>commons-io:commons-io</code>	2.4	2.7	version bump	MEDIUM	CVE-2021-29425
<code>org.apache.commons:commons-lang3</code>	3.4	3.14.0	version bump	LOW	hygiene (no CVE)

Not Included — Human Follow-Up Required

Item	Reason	Category
<code>mysql:mysql-connector-java</code> GPL-2.0 license	License policy decision required — migrate to JDBC or relicense	MAJOR_REVIEW
JaCoCo 80% line-coverage gate (<code>mvn verify</code>)	Pre-existing intentional failure in demo — <code>mvn clean test</code> passes	BUILD_BROKEN (pre-existing)

CVEs Resolved by This Fix PR

CVE	CVSS	Severity	Dependency	Description
-----	------	----------	------------	-------------

CVE-2021-44228	10.0	CRITICAL	log4j-core/api	Log4Shell — unauthenticated RCE via JNDI injection
CVE-2021-45046	9.0	CRITICAL	log4j-core/api	Log4Shell incomplete-fix bypass
CVE-2019-16943	9.8	CRITICAL	jackson-databind	Polymorphic deserialization RCE via commons-dbc
CVE-2019-14892	9.8	CRITICAL	jackson-databind	Polymorphic deserialization RCE via c3p0
CVE-2019-14893	9.8	CRITICAL	jackson-databind	Polymorphic deserialization RCE via xalan
CVE-2019-14379	9.8	CRITICAL	jackson-databind	Polymorphic deserialization RCE via default typing
CVE-2021-20190	8.1	HIGH	jackson-databind	Deserialization RCE
CVE-2020-36518	7.5	HIGH	jackson-databind	StackOverflowError DoS via large JSON
CVE-2022-42003	7.5	HIGH	jackson-databind	Deep recursion DoS
CVE-2022-42004	7.5	HIGH	jackson-databind	Deep recursion DoS
CVE-2022-25647	7.7	HIGH	guava	Deserialization via Gson TypeAdapters
CVE-2021-44832	6.6	MEDIUM	log4j-core	Attacker-controlled config leads to RCE
CVE-2023-21971	5.3	MEDIUM	mysql-connector-java	Unauthenticated network DoS
CVE-2021-29425	4.8	MEDIUM	commons-io	Relative path traversal in FileNameUtils

Stage 4 Gate Verdict (Pre-Merge Baseline on `main`)

Check	Result	Detail
<code>mvn clean test</code>	PASS	2/2 tests pass on fix branch
OWASP CVE (0 CRITICAL/HIGH unresolved)	BLOCK	Resolved in fix PR; <code>main</code> still vulnerable
Supply-chain audit	BLOCK	Typosquat + HTTP mirror removed in fix PR
JaCoCo 80% coverage (<code>mvn verify</code>)	WARN	Pre-existing intentional failure — not caused by this run

Gate will re-run on the fix PR via the `pull_request` workflow. Expected post-merge verdict: **PASS** (pending license MAJOR_REVIEW resolution).

Report Artifacts

File	Stage	Purpose
<code>depscan-report.json</code>	Stage 1	Normalized CVE + supply-chain findings
<code>depscan-risk-report.json</code>	Stage 2	Weighted risk rankings
<code>depscan-reports/CVE-Report.md</code> / <code>.pdf</code>	Stage 1	Human-readable CVE report
<code>depscan-reports/Risk-Scoring-Report.md</code> / <code>.pdf</code>	Stage 2	Prioritized risk backlog
<code>depscan-reports/Audit-Trail-Report.md</code> / <code>.pdf</code>	Stage 5	This consolidated report